

INFORMATION SECURITY POLICY

VitalCloud Health
ISO/IEC 27001:2022 / HIPAA Compliant

Document Title	Information Security Policy
Document Number	VC-POL-ISP-001
Version	1.0
Classification	Internal — Confidential
Author	GRC Consulting Team / CISO
Owner	Chief Information Security Officer (CISO)
Approved By	Chief Executive Officer (CEO)
Issue Date	May 11, 2026
Next Review Date	May 11, 2027
Distribution List	All Departments, Executive Team, HR, IT, Legal, Compliance, All Clinic Staff

CONFIDENTIALITY NOTICE

This document is the property of VitalCloud Health and is classified as Internal — Confidential. Unauthorized disclosure, copying, or distribution is strictly prohibited. Violations may result in disciplinary action, including termination, and may have legal consequences under HIPAA and applicable data protection laws.

1. Policy Overview

1.1 Purpose

This Information Security Policy establishes VitalCloud Health's framework for protecting the confidentiality, integrity, and availability of information assets, with particular emphasis on Protected Health Information (PHI) as defined by the Health Insurance Portability and Accountability Act (HIPAA). This policy defines the security principles, responsibilities, and controls necessary to safeguard patient data, telemedicine systems, medical devices, and corporate resources from internal and external threats.

1.2 Scope

This policy applies to all employees, contractors, independent practitioners, vendors, Business Associates, and third parties who access, process, store, or transmit VitalCloud Health's information assets, including:

- Data hosted on-premises, in cloud environments (AWS/Azure), and on legacy clinic servers
- Telemedicine video streams, mobile applications, and web portals
- IoT medical devices (wearable heart monitors, imaging equipment)
- Paper records at Legacy Care Clinics
- All devices (corporate and BYOD) used to access PHI or corporate systems

1.3 Objectives

- Protect sensitive patient health information (PHI) in compliance with HIPAA Privacy and Security Rules.
- Maintain compliance with applicable regulations (HIPAA, HITECH Act, state privacy laws) and standards (ISO 27001:2022).
- Prevent unauthorized access, disclosure, alteration, or destruction of information assets, including telemedicine data and IoT device data.
- Ensure business continuity of telemedicine services and clinic operations through effective risk management and control implementation.
- Enable the organization to achieve ISO 27001:2022 certification and secure the national insurance provider contract.

1.4 Policy Statement

VitalCloud Health commits to establishing and maintaining a secure environment that protects information assets through the implementation of risk-based controls, continuous monitoring, staff awareness initiatives, and strict adherence to HIPAA requirements. All personnel are responsible for upholding this policy and reporting any security concerns or incidents immediately.

2. Information Security Governance

2.1 Roles and Responsibilities

- Board of Directors: Provides oversight and approves major information security policies, risk appetite, and resource allocation.
- Chief Executive Officer (CEO): Ultimate accountability for information security and HIPAA compliance.
- Chief Information Security Officer (CISO): Leads the Information Security Program, ensures alignment with business objectives, and oversees ISO 27001 and HIPAA compliance.
- HIPAA Privacy Officer: Ensures compliance with HIPAA Privacy Rule, manages patient rights, and oversees PHI use and disclosure.
- HIPAA Security Officer: Implements and maintains HIPAA technical, physical, and administrative safeguards.
- IT and Security Teams: Implement security controls, monitor systems, manage incidents, and ensure encryption of PHI.
- Department Heads: Ensure departmental compliance with security policies and support awareness training.
- Employees, Contractors, and Independent Practitioners: Follow established procedures, protect PHI, and report security incidents promptly.

2.2 Management Commitment

Management shall allocate appropriate resources for security initiatives, risk assessments, HIPAA gap remediation, awareness programs, and the migration of Legacy Care Clinics to secure, compliant systems. Management commits to reviewing this policy annually and upon significant organizational, technological, or regulatory changes.

2.3 Legal and Regulatory Compliance

VitalCloud Health shall comply with all applicable data protection laws, healthcare regulations, and contractual obligations, including:

- Health Insurance Portability and Accountability Act (HIPAA) — Privacy Rule, Security Rule, and Breach Notification Rule
- Health Information Technology for Economic and Clinical Health (HITECH) Act
- ISO/IEC 27001:2022 Information Security Management Standard
- State-specific health data privacy laws
- Business Associate Agreements (BAAs) with all vendors and partners handling PHI

3. Information Classification and Handling

3.1 Classification Levels

Information shall be classified as follows, with specific handling requirements for PHI:

Classification Level	Description	Examples
Confidential / Restricted	PHI and highly sensitive data requiring the highest level of protection. Unauthorized disclosure could cause severe harm to patients or the organization.	Patient medical records, lab results, diagnoses, treatment plans, SSNs, insurance IDs, telemedicine video recordings, encryption keys
Internal	Business operations data not intended for public disclosure but not classified as PHI. Unauthorized disclosure could cause moderate harm.	Internal communications, operational procedures, staff schedules, financial reports, audit results
Public	Information approved for public release. Unauthorized disclosure causes no harm.	Marketing materials, press releases, public website content, general service descriptions

3.2 Handling Requirements

Each classification must have specific storage, access, and transmission controls:

- Confidential / Restricted (PHI): Must be encrypted at rest (AES-256) and in transit (TLS 1.3). Access restricted to authorized personnel on a need-to-know basis. Logging and auditing required. Minimum retention per HIPAA (6 years). Secure disposal (NIST 800-88) before destruction.
- Internal: Stored on secure corporate systems. Access controlled via RBAC. Encrypted in transit over public networks.
- Public: No special handling requirements. Must be approved by Marketing/Legal before release.

4. Access Control

4.1 User Access Management

Access rights shall be granted on a least privilege and need-to-know basis. User accounts must be authorized, documented, and reviewed quarterly. Role-Based Access Control (RBAC) is enforced for all systems containing PHI. Access requests require manager approval and are provisioned by the IT Security team.

4.2 Authentication and Authorization

All systems shall use secure authentication methods. Multi-Factor Authentication (MFA) is mandatory for all users accessing PHI, telemedicine platforms, EHR systems, and administrative consoles. Privileged accounts (system administrators, database administrators) must have:

- Stronger password policies (minimum 16 characters, complexity requirements)
- Just-in-Time (JIT) access where possible
- Session monitoring and recording
- Quarterly access reviews by the CISO or designee

4.3 Access Review

Line managers and system owners must review user access at least every three months. Terminated employees and contractors must have access revoked within 24 hours. Independent practitioners' access is reviewed monthly due to their non-employee status. Access reviews are documented and retained for audit purposes.

5. Asset Management

5.1 Asset Inventory

All hardware, software, data assets, IoT medical devices, and encryption keys must be identified, inventoried, and assigned an owner. The Asset Register includes:

- Telemedicine servers, web portals, and mobile application infrastructure
- IoT devices (wearable heart monitors, imaging equipment from Legacy Care Clinics)
- Workstations, laptops, and mobile devices used to access PHI
- Encryption keys and cryptographic modules
- Paper records at Legacy Care Clinics

5.2 Acceptable Use

Employees, contractors, and independent practitioners shall use VitalCloud Health's information systems responsibly and only for authorized business purposes. Prohibited activities include:

- Accessing PHI without a legitimate business need
- Installing unauthorized software or connecting unapproved devices to corporate networks
- Using personal email or cloud storage for PHI transmission
- Sharing login credentials or MFA tokens
- Photographing or screenshooting PHI on personal devices

6. Physical and Environmental Security

6.1 Secure Areas

Data centers, server rooms, and areas containing PHI (including Legacy Care Clinics) must be restricted to authorized personnel only. Controls include:

- Electronic access control systems (key cards, biometric readers)
- CCTV surveillance with 90-day retention
- Visitor logs and escort requirements
- Intrusion detection and alarm systems
- Environmental controls (fire suppression, climate control, UPS systems)

6.2 Equipment Security

All computing equipment, IoT medical devices, and mobile devices shall be secured against theft, damage, or unauthorized access. Mobile devices containing PHI must be encrypted

and enrolled in Mobile Device Management (MDM). Equipment disposal requires secure wiping (NIST 800-88) or physical destruction, with certificates of destruction retained.

7. Human Resource Security

7.1 Pre-Employment

Background verification shall be conducted for all new hires, contractors, and independent practitioners as permitted by law. Verification includes criminal background checks, professional license verification (for practitioners), and reference checks. Results are reviewed by HR and Security before access to PHI is granted.

7.2 Security Awareness and HIPAA Training

All employees, contractors, and independent practitioners must undergo:

- Annual information security awareness training (ISO 27001, phishing, password security)
- Annual HIPAA Privacy and Security Rule training
- Quarterly phishing simulations targeting telehealth and clinic staff
- Role-specific training for privileged users, developers, and clinical staff
- Training on secure telemedicine practices and patient privacy

Training completion is tracked, and non-compliance is escalated to management.

7.3 Disciplinary Process

Violations of this policy, including HIPAA violations, may result in disciplinary actions up to and including termination and legal action. Violations include unauthorized access to PHI, failure to report incidents, bypassing security controls, and negligent handling of patient data. All disciplinary actions are documented and retained.

8. Cryptography

8.1 Encryption Standards

Confidential and sensitive information, including all PHI, must be encrypted using industry-standard algorithms:

- Data at Rest: AES-256 encryption for databases, file systems, backups, and mobile devices
- Data in Transit: TLS 1.3 for all web and API communications; IPsec for site-to-site VPNs
- Telemedicine Video Streams: End-to-end encryption (E2EE) using AES-256-GCM
- Email Containing PHI: S/MIME or TLS encryption
- IoT Device Data: AES-128 or higher for data transmission from wearable heart monitors and imaging equipment

8.2 Key Management

Cryptographic keys must be securely stored in Hardware Security Modules (HSMs) or cloud Key Management Services (KMS). Key management practices include:

- Key generation using cryptographically secure random number generators
- Key rotation at least annually or upon compromise
- Secure key distribution with access logging
- Key retirement and secure destruction per documented procedures
- Separation of duties between key custodians and system administrators

9. Operations Security

9.1 Change Management

All changes to IT systems, telemedicine platforms, EHR systems, and network infrastructure must follow a formal change approval process with:

- Security impact assessment
- HIPAA compliance review
- Rollback plans and testing in non-production environments
- Approval by Change Advisory Board (CAB) for high-risk changes
- Documentation of all changes and their security implications

9.2 Malware Protection

All endpoints, servers, and telemedicine infrastructure must have updated anti-malware and endpoint detection and response (EDR) software. Real-time scanning is enabled. Malware definitions are updated automatically. Quarterly malware simulation tests are conducted.

9.3 Backup

Critical data, including EHR databases, telemedicine session logs, and patient records, shall be backed up daily. Backups are:

- Encrypted using AES-256
- Stored offsite and in geographically separated cloud regions
- Tested for restoration quarterly
- Retained per HIPAA requirements (minimum 6 years)
- Protected against ransomware via immutable backup storage (WORM)

9.4 Logging and Monitoring

Security logs must be collected, reviewed, and retained in accordance with HIPAA and regulatory requirements. Logging covers:

- All access to PHI (who, what, when, where)
- Authentication events (successes and failures)
- Administrative actions on EHR and telemedicine systems
- Network traffic and firewall logs
- IoT device connections and data transmissions

Logs are centralized in a SIEM, reviewed daily by the Security Operations Center (SOC), and retained for at least 6 years.

9.5 Secure Disposal

Media and devices containing sensitive data must be securely wiped (NIST 800-88 Clear/Purge) or physically destroyed before disposal. Paper records must be shredded using cross-cut shredders. Certificates of destruction are retained for audit purposes.

10. Network and Communications Security

10.1 Network Segmentation

Internal networks must be segmented to separate sensitive systems from general user networks. Segmentation includes:

- Isolation of EHR databases from general corporate networks
- Dedicated VLAN for telemedicine video streaming infrastructure
- Separate network segment for IoT medical devices with restricted outbound access
- DMZ for public-facing web portals and APIs
- Guest network isolation for visitors and patients

10.2 Firewalls and Monitoring

Next-generation firewalls, intrusion detection/prevention systems (IDS/IPS), and network monitoring must be implemented at all network perimeters. Network traffic is analyzed for anomalies, unauthorized access attempts, and data exfiltration. Alerts are escalated to the SOC within 15 minutes.

10.3 Secure Transmission

All sensitive data, including PHI and telemedicine video streams, transmitted over public networks must use TLS 1.3 or equivalent encryption. VPN connections are required for remote access to corporate systems. API communications use OAuth 2.0 + TLS 1.3. Email containing PHI must be encrypted (S/MIME or TLS).

11. Incident Management

11.1 Incident Response

All security incidents, including suspected PHI breaches, must be reported immediately to the Security Operations Center (SOC) or designated response team. Reporting channels include:

- Security hotline: [Phone Number]
- Email: security@vitalcloud.health
- Internal incident reporting portal

Incidents involving PHI are assessed for breach determination per HIPAA Breach Notification Rule. If a breach is confirmed:

- Affected individuals are notified within 60 days

- HHS is notified within 60 days (or immediately if >500 individuals affected)
- Media notification is provided if >500 individuals in a state/jurisdiction are affected

11.2 Evidence Handling

Incident evidence must be preserved and documented according to chain-of-custody requirements. Digital forensics procedures ensure evidence integrity for potential legal proceedings, OCR investigations, or insurance claims. Evidence retention follows legal hold requirements.

11.3 Post-Incident Review

Lessons learned from incidents shall be used to improve processes, update controls, and prevent recurrence. Post-incident reviews are conducted within 30 days of incident resolution and include root cause analysis, control gap identification, and action item assignments.

12. Business Continuity and Disaster Recovery

12.1 Planning

VitalCloud Health shall maintain and test business continuity and disaster recovery plans to ensure service resilience for telemedicine operations and clinic services. Plans include:

- Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) for critical systems
- Failover procedures for telemedicine platform and EHR systems
- Alternative communication methods for doctors and patients during outages
- Manual procedures for Legacy Care Clinics during system unavailability
- Annual tabletop exercises and semi-annual technical recovery tests

12.2 Backup and Restoration

Critical systems must have offsite and cloud-based backup copies with immutable storage. Restoration tests are conducted quarterly. Legacy Care Clinics' paper records must have scanned backup copies stored securely in the cloud EHR system.

13. Third-Party Security

13.1 Vendor Management

Third parties (Business Associates) must undergo security due diligence before engagement. Due diligence includes:

- Security questionnaire and evidence of ISO 27001 or HITRUST certification
- Review of HIPAA compliance history and any OCR enforcement actions
- Technical security assessment (vulnerability scans, penetration testing results)
- Execution of a Business Associate Agreement (BAA) before PHI access is granted
- Annual re-assessment of vendor security posture

13.2 Data Sharing

All data sharing with vendors must be governed by contractual clauses ensuring confidentiality, data protection, and HIPAA compliance. Minimum necessary standard applies — only the minimum PHI necessary for the vendor's function is shared. Data sharing is logged and audited.

14. Compliance and Audit

14.1 Monitoring and Review

Information security controls and this policy shall be reviewed at least annually or upon significant organizational, technological, or regulatory change. Monitoring includes:

- Continuous vulnerability scanning and penetration testing
- Quarterly access reviews and privilege audits
- Monthly SIEM log review and anomaly detection
- Annual internal audits (ISO 27001 and HIPAA)
- External certification audits for ISO 27001

14.2 Non-Compliance

Employees, contractors, and independent practitioners who violate this policy may face disciplinary action up to and including termination and legal consequences. Violations may also be reported to regulatory authorities (HHS/OCR) and law enforcement as required by law.

15. Policy Review and Maintenance

This policy shall be reviewed at least annually or upon significant organizational, technological, or regulatory change. Reviews are conducted by the CISO, HIPAA Security Officer, and Legal/Compliance team. Changes are communicated to all personnel via email, intranet, and staff meetings. Version control is maintained, and previous versions are archived for audit purposes.

16. Approval and Acknowledgement

All employees, contractors, and independent practitioners must acknowledge that they have read, understood, and agree to comply with this Information Security Policy.

Acknowledgement is documented via electronic signature in the HR/training portal and retained for the duration of employment/engagement plus 6 years per HIPAA requirements.

Name	Title	Signature	Date
	Chief Executive Officer (CEO)	_____	_____
Daniel Nwachukwu	Chief Information	_____	_____

	Security Officer (CISO)		
	HIPAA Security Officer	_____	_____

This document is the property of VitalCloud Health. Unauthorized disclosure, copying, or distribution is prohibited. For questions regarding this policy, contact the CISO or HIPAA Security Officer.